

EPIC 04 Task 05 — Security Testing & API Audit

Objective: Test the APIs for authentication, authorization, and token-related security issues and prepare a security audit report.

1. Invalid Token

- Send a request with an invalid or incorrectly formatted JWT token.
- Expected result: **401 Unauthorized**.
- Verify that no protected data is returned.

2. Expired Token

- Use a JWT whose expiration time (exp) has passed.
- Send a request to a protected endpoint.
- Expected result: **401 Unauthorized**.
- The API must reject the expired token.

3. Missing Token

- Call a protected API without an Authorization header.
- Expected result: **401 Unauthorized**.
- Verify that the endpoint cannot be accessed without authentication.

4. Wrong Role

- Authenticate as a user with insufficient permissions, such as a normal user accessing an admin endpoint.
- Expected result: **403 Forbidden**.
- Verify that role-based access control is working correctly.

5. Token Tampering

- Modify the JWT payload or signature and send the modified token.
- Expected result: **401 Unauthorized**.
- The server must validate the JWT signature and reject the tampered token.

6. Unauthorized Endpoints

- Try accessing endpoints that the authenticated user does not have permission to access.
- Expected result: **403 Forbidden** for authenticated users without the required role, or **401 Unauthorized** when authentication is required but absent/invalid.
- Verify that sensitive endpoints are properly protected.

Security Audit Report

Test Case	Expected Result	Status
Invalid token	401 Unauthorized	Pass
Expired token	401 Unauthorized	Pass
Missing token	401 Unauthorized	Pass
Wrong role	403 Forbidden	Pass
Token tampering	401 Unauthorized	Pass
Unauthorized endpoint	401/403 as appropriate	Pass

Conclusion

The APIs were tested for authentication, authorization, JWT validation, role-based access control, and unauthorized access.

The security controls should ensure that invalid, expired, missing, or tampered tokens are rejected, and that users cannot access endpoints outside their assigned roles.